

Security+ 2.4 · On-path Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4 — On-path Attacks (5:30)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: On-path (formerly man-in-the-middle): the attacker sits in the MIDDLE of the communication and INTERCEPTS or ALTERS traffic. ARP spoofing (lying in the local MAC table so traffic flows through the attacker); evil twin AP; DNS poisoning. Defenses: TLS everywhere (the S matters), VPN on public networks, ARP inspection.

High-Yield Core Concepts Tested on Exam

- On-path (formerly MITM): intercepts and/or alters communication
- ARP spoofing: lies about the MAC — redirects traffic to the attacker
- Defense #1: HTTPS everywhere (TLS authenticates the endpoint)
- DNS poisoning redirects name resolution to attacker-controlled hosts
- VPN on public networks protects against on-path interception

Exam Tips & Classic Scenarios

- 'traffic intercepted between two parties' = on-path/MITM
- ARP spoofing is the foundation of on-path attacks on local networks

Typical Exam Scenario: Scenario: 'a computer inside the network receives traffic that should have gone to another machine' = ARP spoofing (the basis of on-path).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — On-path Attacks)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **MAC:** Mandatory Access Control: Rigid label-based access architecture (Top Secret, Secret, Unclassified) enforced centrally by security kernel according to formal classification policies.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Attacker positions between two parties and intercepts/alters communication. This is:

- A)** On-path attack (MITM)
- B)** Denial of service
- C)** SQL injection
- D)** Brute force

2. What type of attack exploits vulnerabilities before a patch is available?

- A)** Zero-day attack
- B)** DDoS attack
- C)** Brute force attack
- D)** Man-in-the-Middle attack

3. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'On-path (formerly MITM): intercepts and/or alters communication'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Implement the corresponding solution: On-path (formerly MITM): intercepts and/or alters communication...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'ARP spoofing: lies about the MAC — redirects traffic to the attacker'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: ARP spoofing: lies about the MAC — redirects traffic to the attacker...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Defense #1: HTTPS everywhere (TLS authenticates the endpoint)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Defense #1: HTTPS everywhere (TLS authenticates the endpoint)...
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'traffic intercepted between two parties' = on-path/MITM'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'traffic intercepted between two parties' = on-path/MITM...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'a computer inside the network receives traffic that should go to another machine' = ARP spoofing (the basis of on-path)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'a computer inside the network receives traffic that should go to another machine' = ARP spoofing (the basis of on-path)...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'On-path (formerly MITM): intercepts and/or alters communication'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: On-path (formerly MITM): intercepts and/or alters communication...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'ARP spoofing: lies about the MAC — redirects traffic to the attacker'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: ARP spoofing: lies about the MAC — redirects traffic to the attacker...

10. Corporate scenario (On-path Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Defense #1: HTTPS everywhere (TLS authenticates the endpoint)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Defense #1: HTTPS everywhere (TLS authenticates the endpoint).
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — On-path attack (MITM).

✓ **Why it's correct:** The correct answer is 'On-path attack (MITM)'. An on-path attack, also known as man-in-the-middle (MITM), occurs when an attacker secretly positions between two parties who believe they are communicating directly. The attacker can intercept, alter, or relay messages without the parties noticing. The statement describes exactly this scenario: the attacker positions between two parties and intercepts/alters communication. CompTIA uses the term 'on-path attack' as a synonym for MITM, making it the precise answer for the description.

✗ **Why the others are wrong:**

- *Denial of service:* Denial of service (DoS) is an attack that aims to make a service, network, or system unavailable to legitimate users, usually by overwhelming it with malicious traffic. It does not involve interception or alteration of communication between two parties. The goal is to disrupt the service, not to spy on or modify data. Therefore, DoS does not apply to the described scenario.
- *SQL injection:* SQL injection is an attack technique that exploits vulnerabilities in web applications that do not properly validate user input, allowing execution of malicious SQL commands in the database. It has no relation to intercepting communication between two parties. It is an injection attack, not a man-in-the-middle positioning. Therefore, SQL injection is incorrect.
- *Brute force:* Brute force is an attack method that consists of exhaustively trying all possible combinations of passwords or keys to gain unauthorized access. It does not involve interception or alteration of traffic. It is a guessing attack, not a positioning between parties. Therefore, brute force is not the correct answer.

2) A — Zero-day attack.

✓ **Why it's correct:** The correct answer is 'Zero-day attack'. A zero-day attack exploits a vulnerability that is unknown to the software or hardware vendor, or for which no patch is yet available. The term 'zero-day' refers to the fact that exploitation occurs before the developer has had the opportunity to fix the flaw, or on the same day the vulnerability becomes known. These attacks are particularly dangerous because they cannot be mitigated by antivirus signatures or traditional patches, requiring proactive defenses such as behavioral analysis, sandboxing, and network segmentation. In CompTIA Security+, the zero-day concept is associated with advanced threats and the need for defense-in-depth strategies.

✗ **Why the others are wrong:**

- *DDoS attack:* A DDoS (Distributed Denial of Service) attack aims to overwhelm a service, server, or network with massive traffic from multiple sources, making it unavailable to legitimate users. It does not exploit a specific software vulnerability for which no patch exists; instead, it abuses resource capacity and bandwidth. Although it can be devastating, DDoS does not fit the definition of a zero-day attack, as it does not depend on an unknown and unpatched flaw. Mitigation involves traffic filtering, CDNs, and anti-DDoS services, not patch application.
- *Brute force attack:* A brute force attack attempts to guess credentials (passwords, keys) through exhaustive and repeated attempts, often automated. It exploits weak or predictable passwords, not an unpatched software vulnerability. Although it can be used for initial access, it is not classified as a zero-day attack. Defenses include strong password policies, account lockout, multi-factor authentication, and rate limiting, and do not depend on a specific patch for an unknown flaw.
- *Man-in-the-Middle attack:* A Man-in-the-Middle (MitM) attack occurs when an adversary positions themselves between two communicating parties, intercepting and possibly altering traffic. It exploits authentication flaws, weak encryption, or insecure configurations (e.g., ARP spoofing, DNS spoofing), but is not defined by exploiting an unpatched vulnerability. MitM can be

mitigated with strong encryption, digital certificates, and mutual authentication. It is not to be confused with zero-day, which specifically refers to an unknown and unpatched vulnerability.

3) B — Implement the corresponding solution: On-path (formerly MITM): intercepts and/or alters communication....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks): On-path (formerly MITM): intercepts and/or alters communication.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

4) B — Implement the corresponding solution: ARP spoofing: lies about the MAC — redirects traffic to the attacker....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks): ARP spoofing: lies about the MAC — redirects traffic to the attacker. ARP spoofing involves sending falsified ARP messages to associate the attacker's MAC address with the IP address of a legitimate host, causing traffic intended for that host to be sent to the attacker. This enables on-path (man-in-the-middle) attacks, session hijacking, and data interception. Mitigations include dynamic ARP inspection (DAI) and static ARP entries.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: Defense #1: HTTPS everywhere (TLS authenticates the endpoint)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks): Defense #1: HTTPS everywhere (TLS authenticates the endpoint). On-path attacks (formerly man-in-the-middle) intercept communications between two parties. TLS encryption with proper certificate validation ensures the endpoint is authenticated and data integrity is maintained, preventing eavesdropping and tampering.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'traffic intercepted between two parties' = on-path/MITM....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks): 'traffic intercepted between two parties' = on-path/MITM.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Scenario: 'a computer inside the network receives traffic that should go to another machine' = ARP spoofing (the basis of on-path).....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks): Scenario: 'a computer inside the network receives traffic that should go to another machine' = ARP spoofing (the basis of on-path). ARP spoofing involves sending falsified ARP messages to associate the attacker's MAC address with the IP address of a legitimate host, causing traffic intended for that host to be redirected to the attacker. This enables on-path (man-in-the-middle) attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: On-path (formerly MITM): intercepts and/or alters communication....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks): On-path (formerly MITM): intercepts and/or alters communication.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

9) D — Implement the corresponding solution: ARP spoofing: lies about the MAC — redirects traffic to the attacker....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks): ARP spoofing: lies about the MAC — redirects traffic to the attacker.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Defense #1: HTTPS everywhere (TLS authenticates the endpoint)..

The correct answer is to implement the corresponding solution: enforce HTTPS everywhere. According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (On-path Attacks), TLS provides encryption and endpoint authentication, which prevents on-path attackers from intercepting or modifying traffic. Using HTTPS universally is the primary defense against such attacks. Distractor breakdown: • *Temporarily disable audit logs to accelerate system throughput*: Incorrect. This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001). • *Replace preventive technical controls with informal terms of adherence*: Incorrect. Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware. • *Allow shared access among administrators using generic credentials*: Incorrect. This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.